

IT Access and Usage Policy Reference Standard

Reference version showing stronger control language and fuller governance coverage

Field	Value
Document Owner	Chief Information Security Officer
Version	2.0
Effective Date	2026-01-15
Review Cycle	Annual
Classification	Internal Control Reference

1. Purpose

This standard defines mandatory controls for provisioning, using, monitoring, reviewing, and revoking access to organizational technology resources. It is intended to protect confidentiality, integrity, and availability while enabling business operations in a controlled manner.

This document also establishes minimum requirements for acceptable use, authentication, device protection, remote access, logging, exception handling, and disciplinary response so that technology controls are applied consistently across the organization.

2. Scope

This standard applies to all employees, contractors, interns, vendors, and service providers with logical or physical access to company-managed endpoints, infrastructure, applications, cloud platforms, collaboration environments, development tools, and data repositories.

Any locally developed procedures must be consistent with this standard and may only impose stricter requirements, not weaker ones.

3. Access Governance

All access must be approved by the relevant manager and provisioned according to documented role-based access requirements. Access rights must be limited to the minimum necessary for a user to perform assigned duties.

Privileged access must be separately approved, documented, and reviewed at least quarterly. Shared accounts are prohibited except where a documented technical constraint exists and compensating controls have been approved by Information Security.

- User access requests must identify requested systems, access level, business justification, requestor, approver, and target start date.
- Temporary access must include an explicit end date and expire automatically where feasible.

- Access for terminated personnel must be revoked immediately upon separation, and access for transfers must be adjusted within one business day.

4. Authentication Requirements

Multi-factor authentication is required for remote access, administrative access, privileged actions, and access to systems that process confidential, regulated, or business-critical information.

Passwords must comply with corporate password standards, including minimum length, prohibited reuse, and technical protections against default or known-compromised passwords. Service account credentials must be stored securely and rotated on a documented schedule.

5. Acceptable Use

Technology resources may be used only for authorized business activity and limited personal use that does not create material risk, cost, legal exposure, or interference with operations. Users must not install unauthorized software, disable endpoint protections, circumvent access restrictions, or use company resources to store or transmit inappropriate or unlawful content.

Business data must be processed only through approved systems. Forwarding company information to personal email, transferring sensitive data to unauthorized cloud services, or using unapproved AI tools for confidential content is prohibited unless explicitly authorized and risk-assessed.

6. Devices and Endpoint Security

All company-managed devices must be enrolled in centralized management and configured with disk encryption, endpoint protection, automated patching, screen lock controls, and inventory tracking. Unsupported operating systems or unmanaged devices may not be used to access internal systems without a documented exception.

Bring-your-own-device access, if permitted, must be governed by approved mobile-device-management controls, minimum security baselines, and data separation requirements.

7. Remote Access and Network Use

Remote connections to internal resources must use approved secure access methods such as the corporate VPN or equivalent managed access service. Administrative access from public networks must use encrypted channels and MFA.

Users must not connect company devices to untrusted networks for sensitive work without approved protections. High-risk geographies, unusual sign-in behavior, and repeated failed login attempts must be monitored and investigated.

8. Logging, Monitoring, and Privacy Notice

The organization must log authentication events, privileged actions, critical administrative changes, remote connections, and security alerts for systems within scope. Security logs must be retained according to the logging standard and reviewed for indicators of misuse or compromise.

Users are informed that company systems are monitored for security, compliance, capacity, troubleshooting, and investigations. Monitoring must be proportionate, authorized, and aligned to legal and privacy obligations.

9. Access Reviews, Incidents, and Exceptions

Managers and system owners must perform periodic access reviews at least quarterly for privileged users and at least semi-annually for other high-risk systems. Review outcomes must be documented and remediation tracked to completion.

Suspected unauthorized access, phishing, malware, credential disclosure, or device loss must be reported immediately to the service desk or security function. Exceptions must be documented with business rationale, risk assessment, compensating controls, approver, and expiry date.

10. Enforcement and Governance

Violations of this standard may lead to disciplinary action up to and including termination, legal referral, financial recovery, or suspension of access. This standard is owned by Information Security, reviewed annually, and supported by procedures for onboarding, offboarding, logging, remote work, and endpoint management.